

Case Study: Navigating AI, Privacy, and Trust in the PDPA Era

Background

New Telecom Ltd., one of Bangladesh's leading telecommunications operators, has been serving millions of customers for more than 20 years. Established during the early years of the country's telecom industry, the company has grown alongside Bangladesh's digital transformation. Throughout this journey, it has continuously adapted its operations, policies, and governance frameworks to remain compliant with Bangladesh's evolving legal and regulatory requirements. Today, it manages vast amounts of customer information, including subscriber identity records, billing information, communication metadata, digital payment information, location data, and data generated through various digital platforms. Protecting these information assets has become as important as maintaining network availability.

Current Scenario

Today, New Telecom Ltd. maintains a dedicated Cyber Security and Data Privacy Division responsible for safeguarding organizational assets, protecting customer information, and ensuring regulatory compliance. The team collaborates closely with business units, Legal, Technology, and Risk Management functions to embed security and privacy considerations across business operations.

To strengthen its cybersecurity and privacy posture, the company has implemented several key initiatives, including:

- Adoption of a Privacy Governance Framework aligned with international standards to ensure responsible collection, processing, storage, and sharing of personal data.
- Privacy-by-Design Implementation, integrating privacy controls into systems and business processes from the outset while enforcing least-privilege and Zero Trust access to personal data.
- Strong Data Protection Controls, including data classification, encryption, data loss prevention (DLP), continuous monitoring, and regular privacy compliance reviews.
- Ongoing Privacy Awareness and Training for employees, vendors, and customers to promote responsible handling of personal information and compliance with privacy regulations.
- Adoption of an internationally benchmarked Cybersecurity Framework for effective cyber risk management.
- Conducting privacy risk assessments before data processing activities.
- Performing regular vulnerability assessments, penetration testing, and continuous security monitoring.
- Delivering ongoing awareness and training programs for employees, business partners, and customers.

These initiatives have significantly enhanced the organization's overall security and privacy maturity. However, as technology continues to evolve and regulatory expectations become

complex, data privacy risks are emerging at an unprecedented pace, necessitating continuous vigilance and enhancement of controls and capabilities.

The New Reality & Emerging Risks

As digital services expanded, the company evolved from being a traditional telecommunications operator by integrating digital capabilities into its existing operations.

New Telecom Ltd is now accelerating its digital transformation by developing AI-enabled web and mobile applications to improve customer experience, automate business processes, and support data-driven decision-making. These applications collect and process large volumes of personal and sensitive data, including customer profiles, financial information, location data, employee records, and behavioral analytics.

Several AI-powered solutions are currently under consideration for deployment, including:

- 1 AI-enabled customer support assistants
- 2 Intelligent fraud detection systems
- 3 Customer churn prediction models
- 4 Marketing recommendation engines
- 5 Network optimization using machine learning
- 6 Automated document processing

Integration of Artificial Intelligence (AI) has introduced new opportunities for business but opened a new attack surface for threat actors. Cybercriminals are increasingly leveraging AI to automate attacks, generate convincing phishing campaigns, develop malware capable of adapting to security controls, bypass identity verification mechanisms, and identify vulnerabilities much faster than traditional techniques.

As the organization embraces AI-powered applications to improve customer service, automate routine operations, and better understand customer behavior, they unlock significant opportunities for innovation and efficiency. However, these benefits also come with new privacy and security challenges that cannot be overlooked. AI systems often rely on large amounts of personal data, increasing the risk of unauthorized data processing or accidental exposure of sensitive information. Decisions made by AI may sometimes be influenced by biased training data, leading to unfair outcomes, while the lack of transparency in automated decision-making can make it difficult for customers to understand how those decisions were reached. The rapid adoption of generative AI has also introduced emerging threats, including prompt injection attacks that manipulate AI responses and model inversion techniques that may reveal sensitive information used during training. At the same time, organizations must carefully consider the risks of sharing data with third-party AI providers, particularly when information is retained externally or transferred across international borders. As AI continues to become an integral part of digital services, addressing these risks through responsible governance, strong security controls, and privacy-by-design practices is essential for maintaining customer trust.

A New Regulatory Environment

Recently, the Parliament of Bangladesh enacted the *Personal Data Protection Act (PDPA)*, introducing a comprehensive legal framework governing the collection, processing, storage, sharing, and protection of personal data.

The new legislation significantly increases organizational responsibilities. Among other expectations, organizations are now required to:

- **Lawful and transparent processing:** Mandates clear grounds for processing and proper notice to data subjects.
- **Data minimization:** Enforces collecting only the information necessary for specified, lawful purposes.
- **Accountability:** Requires organizations to actively manage compliance, secure data integrity, and adhere to statutory obligations.
- **Third-party/Processor compliance:** Imposes duties on controllers to ensure third parties and processors handling data meet mandatory security and confidentiality standards.
- **Individual rights:** Grants data subjects robust rights including access, correction, data portability, and consent withdrawal/opt-out.
- **Prohibitions on Tracking Children:** Organizations are strictly prohibited from conducting targeted advertising, tracking, profiling, or behavioral monitoring directed specifically at children (minors under 18)

While the PDPA provides clear guidance to the relevant stakeholders, some areas need further clarification, for which regulators need to establish their relevant committees or bodies.

The Challenge

Although cybersecurity controls have matured considerably since 2020, privacy activities remain fragmented across different business units. New digital initiatives often involve multiple stakeholders, including application developers, cloud providers, AI vendors, analytics platforms, marketing teams, and external partners. Personal data may flow through numerous systems before reaching its destination, making visibility and governance increasingly difficult.

During an internal review, senior management identified several strategic concerns.

- Where is every piece of customer personal data stored?
- Which applications process sensitive information of customers?
- Which AI systems have access to customer data?
- Which vendors receive customers' personal information?
- What customer data leaves Bangladesh?
- Are all AI-enabled decisions explainable?
- Can the organization demonstrate PDPA compliance during a regulatory audit?
- Who is accountable for privacy decisions across business units?

Assignment

Assume you have been appointed as a Data Privacy Consultant to advise *New Telecom Ltd's* Executive Management.

Prepare a strategic proposal outlining how New Telecom Ltd. can securely adopt artificial intelligence while protecting customer privacy, managing emerging privacy risks, and complying with the Personal Data Protection Act (PDPA). The proposal should provide practical recommendations to strengthen AI governance, secure customer data, enhance employee and customer awareness, strengthen third-party governance, and build long-term customer trust in the organization's digital services.